

Introduction: The Professionalization of Cybercrime

Key Shift: From lone hackers to organized crime-as-a-service.

Analogy: "Cybercrime today isn't a kid in a basement; it's Amazon Web Services for criminals."

Today's Path: Vulnerabilities → Exploitation → Infrastructure → Anonymity → Hardware Tools.

A CRIMINAL'S SHOPPING LIST

1. CVE (Common Vulnerabilities and Exposures)

What it is

A standardized system for identifying publicly known security vulnerabilities.

Format: CVE-YYYY-XXXX(year + id number)

Managed by: MITRE

Used globally by security tools, vendors, and researchers

Why it matters

Prevents confusion when discussing vulnerabilities

Enables consistent patch tracking

Forms the base for vulnerability management systems

How Criminals Use CVEs:

Monitor Lists: NVD (National Vulnerability Database), vendor advisories.

Prioritize by Impact:

Remote Code Execution (RCE): Gold standard for attackers.

Privilege Escalation: Break out of restricted environments.

Zero-Days: Unknown to vendor; highest value.

Case Study: CVE-2021-44228 (Log4Shell)

Critical RCE in Java logging library.

Timeline: Discovered Dec 2021 → Exploited within hours → Mass scanning → Ransomware deployment in days.

Lesson: Time from disclosure to weaponization is now hours.

Criminal Economy Around CVEs:

Zero-Day Markets: Sold to governments, criminals via brokers.

Exploit Kits: Bundled exploits sold/subscribed to (e.g., Angler, Rig).

Proof-of-Concept (PoC) Hunting: GitHub, Exploit-DB, Twitter for public PoCs to weaponize.

Defender Perspective: Patch critical CVEs within 24 hours — criminals automate scanning for unpatched systems.

2. TTPs (Tactics, Techniques, and Procedures)

Definition

Describes how threat actors operate.

Tactics → The goal (e.g., persistence)

Techniques → The method (e.g., registry modification)

Procedures → The exact implementation used

Framework Reference

MITRE ATT&CK Framework

Real-World Attack Chain Example:

Reconnaissance:

Tools: Shodan, Censys, LinkedIn, Hunter.io

Goal: Find email formats, exposed services, employee names.

Initial Access:

Technique: Spear phishing with weaponized document.

Procedure: Use GoPhish framework, host on compromised WordPress site.

Execution & Persistence:

Technique: Scheduled Tasks, Windows Registry.

Tool: Cobalt Strike Beacon, Metasploit payload.

Lateral Movement:

Technique: Pass-the-Hash, SMB exploitation.

Tool: Mimikatz, Impacket toolkit.

Exfiltration & Impact:

Technique: DNS tunneling, HTTPS to cloud storage.

Impact: Ransomware deployment, data theft.

3. The Dark Web

What it is

Part of the internet accessible only through specialized software (e.g., Tor).

Three-Layer Model:

Surface Web: Regular internet (Google, Facebook).

Deep Web: Login-required content (email, banking).

Dark Web: Requires special software (Tor, I2P).

Characteristics

Encrypted routing

Onion domains (.onion)

High anonymity

Common Uses

Privacy-preserving communication

Whistleblowing platforms

Illicit marketplaces

Security Perspective

Source of data leaks and breach dumps

Intelligence gathering for SOC teams

Threat actor monitoring

Communication Channels:

Telegram: Public channels for "carding", "cracking".

Session/Wickr: More secure, disappearing messages.

IRC Over Tor: Old-school but still used.

Payment Systems:

Monero (XMR): Privacy coin of choice (untraceable).

Bitcoin (BTC): Still used but traceable.

Escrow Services: Market-held funds until delivery.

4. Tools of the Trade (Ethical Security Context)

Security professionals use tools for:

Reconnaissance

Scanning

Exploitation testing

Monitoring

Forensics

Categories

Network scanning tools

Web vulnerability scanners

Traffic analyzers

Password auditing tools

SIEM platforms

Important mindset:

Tools don't make a hacker. Understanding systems does.

5. Criminal Tech Stack

This refers to the technology ecosystem cybercriminals use.

C2 servers

Phishing kits

Cryptocurrency wallets

Mixing services

Ransomware payment portals

Malware Development & Distribution:

Builder Kits: Create custom malware without coding.

Crypters: Encrypt malware to evade AV (e.g., VMProtect, Themida).

Distribution: Malvertising, exploit kits, torrents

Infrastructure:

Bulletproof Hosting: In jurisdictions ignoring abuse (e.g., Netherlands, Russia historically).

Compromised Servers: Legitimate websites/servers hacked to host malware.

CDNs & Cloud: Abuse free tiers of AWS, Azure, Cloudflare

OPSEC Tools:

Virtual Machines: Isolate activities.

VPN Chains: Multiple VPN hops.

Anti-Forensics: BleachBit, Disk Wipers.

Burner Devices: Dedicated hardware for illicit activities.

6. Keying Devices & Hardware Tools

1. Flipper Zero:

Capabilities: RFID/NFC cloning, IR remote control, BadUSB, GPIO pins.

Criminal Uses:

Clone office access cards.

Emulate garage door openers.

USB rubber ducky attacks (keystroke injection).

Defense: Monitor for unknown USB devices, disable auto-run.

2. Raspberry Pi / Raspberry Pi Zero:

Drop Box: Small, cheap, runs full Linux.

Uses:

Plant behind target's network for persistent access.

Wi-Fi pineapple attacks (evil twin AP).

Network tap when connected inline.

Setup: Kali Linux, silent boot, SSH over cellular (Pi 4 with LTE hat).

3. "BlackBerry Pi" (Likely meaning modified/hardened Pi):

Concept: Stealth-modified Pi for covert operations.

Mods: Internal battery, magnetic casing for hiding, 4G connectivity.

Use Case: Leave in ceiling tile of target office.

4. Proxmark3 / HackRF:

RFID/NFC/SDR: Clone, sniff, replay wireless signals.

Real Attack: Clone key fobs, intercept garage door codes, jam/replay car signals.

5. USB Rubber Ducky / Bash Bunny:

Keystroke Injection: Pretends to be keyboard, runs pre-programmed attacks.

Example Payload: Open command prompt, download malware, execute.

6. LAN Turtle / Packet Squirrel:

Covert Network Tap: Plant on network, exfiltrate data over SSH.

Hardware Attack Scenarios:

Corporate Espionage: Plant Pi in conference room to record meetings.

Car Hacking: Use SDR to intercept/replay keyless entry signals.

Access Control Bypass: Clone RFID cards to enter secure areas